

SHIVAM SARASWAT

Senior Product Security Engineer

@shivamsaraswat044@gmail.com

+91-9084280701

Bengaluru, Karnataka

shivamsaraswat.com

blog.shivamsaraswat.com

shivamsaraswat

shivamsaraswat

PROFESSIONAL SUMMARY

Senior Product Security Engineer with 4+ years of experience architecting enterprise-grade security platforms, securing CI/CD pipelines, and delivering cloud-native security solutions at scale. Deep expertise in SSDLC automation, container security, vulnerability management, supply chain security, and developer-centric tooling. Known for reducing security risk and alert fatigue, improving remediation speed, and shipping security tooling that developers actually use. Committed to bridging the gap between development and security to create resilient, scalable, and efficient systems.

EXPERIENCE

Senior Product Security Engineer

PayPal

April 2025 – Ongoing

Bengaluru, Karnataka

- Org-Wide Supply Chain Firewall:** Built a multi-stage package security gateway upstream of Artifactory, enforcing age-based blocking, malicious-package checks (OSV.dev), and vulnerability scanning before packages reach developers.
- CI/CD-Native Security Enforcement:** Benchmarked container scanners on accuracy, performance, and cost, then deployed the winning solution across 3,100+ pipelines to auto-block non-compliant images — improving detection coverage by 50%.
- Container Security Framework:** Standardized container vulnerability policy enforcement across all engineering teams, achieving 100% policy compliance and accelerating remediation cycles org-wide.
- Third-Party Vendor Image Scanning:** Designed an automated CI/CD scanning pipeline and standardized vendor onboarding workflows, with a Slack AI bot letting developers trigger scans on demand.
- Vulnerability Deduplication Engine:** Engineered CVE-, package-, and version-level deduplication across container and SCA scanners using image layer-based analysis, cutting alert fatigue and improving patch efficiency by 30%.
- AI-Powered SCA Intelligence:** Prototyped an AI-driven system for reachability analysis (false-positive elimination), safe-version recommendations, and parent-dependency fix suggestions across Maven and npm ecosystems.
- Supply Chain Attack Prevention:** Detected and neutralized the Shai-Hulud self-replicating npm worm and several concurrent supply-chain campaigns, preventing credential theft and lateral spread across build environments.
- Cross-Language Vulnerability Research:** Investigated Go CVEs surfacing in Node.js runtimes and analyzed build-time vs. run-time exploitability, informing org-wide remediation prioritization.
- Container Security Documentation Hub:** Authored ADRs, integration guides, and workflow documentation, reducing developer onboarding time by 40%.

EDUCATION

B.Tech in Computer Science and Engineering (Cyber Security)

GLA University, Mathura

May 2022

8.25 CGPA

SKILLS

Security Expertise:

- AppSec & DevSecOps:** SSDLC, Container Security, Application Security, Cloud Security, Vulnerability Management, Policy as Code, Supply Chain Security, OWASP Top 10
- Security Research:** Root Cause Analysis (RCA), Vulnerability Triage & Prioritization

Security Tools & Platforms:

- SAST:** Semgrep, CodeQL (GHAS)
- SCA & Dependency Management:** Dependabot, Renovatebot, Syft (SBOM)
- Secret Scanning:** GitHub Advanced Security, Gitleaks
- Container Security:** Wiz, JFrog Xray, Trivy
- DAST & Security Testing:** Nuclei, OWASP ZAP, Burp Suite
- Monitoring & Observability:** Elasticsearch, New Relic, Datadog

Core Technical Skills:

- Programming & Scripting:** Python, Bash, Git
- Cloud & Infrastructure:** Google Cloud, AWS, Docker, Kubernetes (K8s)
- CI/CD & DevOps:** GitHub Actions, GitLab CI/CD, Harness CI/CD

Security Engineer

Tekion

📅 August 2024 – March 2025 📍 Bengaluru, Karnataka

- **DevSecOps Pipelines:** Architected and deployed DevSecOps security scanning pipelines — SAST, SCA, Secret Scan, Container Scan, and Dockerfile Scan — across 2,000+ production repositories, achieving a 40% reduction in security vulnerabilities.
- **DevSecOps Pipelines Migration:** Led the migration of 2,000+ production repositories to GitLab's Pipeline Execution Policy with zero production disruption.
- **Pipeline Optimization & DevOps Collaboration:** Partnered with the DevOps team to iterate on security pipeline templates based on operational feedback, cutting execution time by 35% across 2,000+ repositories.

Product Security Engineer

IKEA

📅 April 2023 – August 2024 📍 Bengaluru, Karnataka

- **Automated Security Monitoring ("Heimdall"):** Built an in-house automated web and API security monitoring solution, reducing external engagement costs by 20% and improving the responsible disclosure program's response capability.
- **SSDLC Maturity Platform ("Argos"):** Designed and built an org-wide SSDLC maturity automation platform integrated into IKEA's internal developer portal (built on Spotify's Backstage), providing one-click security enablement, on-demand assessments, maturity scoring, and secure template integration.
- **Security Adoption at Scale:** Onboarded 700+ development teams to Argos with zero-touch auto-onboarding for new teams; transparent, org-visible maturity scores created peer-driven motivation for teams to proactively improve their security posture.
- **Automated Cloud Vulnerability Management & Visualization:** Built an end-to-end triage and notification system with centralized dashboard for Google Security Command Center (SCC), cutting critical-issue response time by 40%.
- **Shadow IT Asset Management:** Identified and remediated 150+ dangling DNS records tied to shadow-IT assets, eliminating subdomain-takeover exposure.
- **Security Awareness:** Delivered 10+ security awareness sessions to non-security staff across engineering and business teams.

Security Automation Engineer

BreachLock

📅 March 2022 - April 2023 📍 Noida, UP

- **Threat Research & Detection Automation:** Researched emerging threats and developed detection automation vulnerability scanners and an external attack surface management platform.
- **Vulnerability Scanner Enhancement:** Improved scanner effectiveness by incorporating vulnerabilities discovered during penetration tests into detection logic and workflows.
- **Security Automation & Testing:** Developed modular security automation plugins with Pytest-based test coverage.

ACCOMPLISHMENTS

🏆 **Best Security Product of the Year**
Awarded for "Heimdall," the automated security monitoring platform I built at IKEA

🦋 **Hackathon Runner Up**
IKEA's InnerSource Hackathon 2024

🎤 **Speaker at BSides Vizag 2025**
Presented – "Breaking Bad: Container Security is Broken" — covering layer-aware vulnerability analysis and threat intelligence (CISA KEV, EPSS) to surface vulnerabilities that actually matter

PERSONAL PROJECTS

🐙 **SeCoRA (Secure Code Review AI Agent)**
AI agent for LLM-driven secure code review — OWASP Top 10/SANS Top 25 detection, vulnerability chaining, and CVSS-scored remediation reports (Python, FastAPI).

PUBLICATIONS

👥 **Conference Proceedings**

- A. Tiwari, S. Saraswat, U. Dixit, and S. Pandey, "Refinements in zeek intrusion detection system," in *2022 8th International Conference on Advanced Computing and Communication Systems (ICACCS)*, vol. 1, 2022, pp. 974–979. DOI: 10.1109/ICACCS54159.2022.9785047.

CERTIFICATIONS

- **EC-Council** - Certified Ethical Hacker (Practical)

LANGUAGES

English ● ● ● ● ●
Hindi ● ● ● ● ●